NOTE 05 - MITRE ATT&CK VS THE CYBER KILL CHAIN

Both models describe an intrusion, but they were built for different purposes and at different levels of detail. The Cyber Kill Chain is a high-level, linear story of an attack; MITRE ATT&CK is a detailed, non-linear catalogue of behaviour.

The Cyber Kill Chain in one table

The Cyber Kill Chain was published by Lockheed Martin in 2011. It has seven phases, and the idea is that stopping the attacker at any phase breaks the chain.

#	Phase	What happens	Example	Possible countermeasure
1	Reconnaissance	Attacker gathers information	Port scanning, LinkedIn scraping	Intelligence, blocking scans
2	Weaponization	Malicious payload is built	Malicious macro in a document	Patch management, user awareness
3	Delivery	Payload is transmitted	Phishing email with attachment	Email filtering, sandboxing
4	Exploitation	Code runs on the victim	Macro opens PowerShell	Application hardening, ASR rules
5	Installation	Attacker establishes persistence	Run key or service installed	EDR, file integrity monitoring
6	Command and Control	Remote channel is opened	HTTPS beacon to a VPS	Proxy filtering, DNS monitoring
7	Actions on Objectives	Attacker achieves the goal	Data theft, ransomware	DLP, backup, segmentation

Comparison table

Aspect	Cyber Kill Chain	MITRE ATT&CK
Author / origin	Lockheed Martin, 2011	MITRE, first public release 2015
Shape of the model	Linear - seven sequential phases	Matrix - tactics as columns, techniques as rows
Focus	The stages of the intrusion	The specific behaviours an adversary performs
Level of detail	Coarse - seven phases in total	Fine - hundreds of techniques and sub-techniques
Vocabulary	Phase names only	Tactic names plus numbered techniques/sub-techniques (`T1059.001`)
Detection detail	Very little - tells you where to look	Explains what to detect and the data source needed to detect it
Best suited to	Explaining an attack to management; perimeter defence; understanding attacker intent	Detection engineering, threat hunting, SOC triage, red/purple teaming, coverage measurement
Number of stages	Fixed at 7	Tactics vary by matrix (about 14 in Enterprise) and grow over time

Aspect	Cyber Kill Chain	MITRE ATT&CK
Treatment of insider threat / non-linear attacks	Weak - assumes an external attacker moving in sequence	Stronger - shows that attackers loop back, re-use techniques and move laterally
Coverage measurement	Possible but very rough ("we have no control at Installation")	Precise - a heat map of techniques with or without detection
Typical deliverable	One-slide attack narrative	TI/CTI rule with ATT&CK tags, coverage report, hunt plan
Main limitation	Too high level for modern, cloud, or fileless attacks; assumes a strict order	Large and can be overwhelming; still cannot describe every event
Relationship to the other	ATT&CK is far more granular than the Kill Chain	The Kill Chain can be seen as a simplified, sequential summary of ATT&CK stages

Where the two line up

Some ATT&CK tactics resemble Kill Chain phases, but they are not the same thing:

Kill Chain phase	Roughly overlaps with ATT&CK tactic(s)
Reconnaissance	Reconnaissance (and Resource Development)
Weaponization	Resource Development
Delivery	Initial Access
Exploitation	Execution (and Exploitation for Privilege Escalation)
Installation	Persistence
Command and Control	Command and Control
Actions on Objectives	Collection, Exfiltration, Impact

Two important differences:

- ATT&CK is not strictly sequential. An attacker can perform Credential Access before getting a foothold (credential phishing) and can repeat Discovery and Lateral Movement many times.
- ATT&CK has far more tactics than the Kill Chain has phases. Defense Evasion, Discovery and Privilege Escalation have no dedicated Kill Chain phase, yet they are some of the most common attacker behaviours a SOC sees.

Which model should the analyst use?

- Use the Cyber Kill Chain to give a short, readable account of an incident to non-technical readers, or to reason about where a control can break an attack.
- Use MITRE ATT&CK for everything operational: tagging detections, triaging alerts, writing hunt hypotheses, measuring coverage and reporting technique-level detail.
- Use both together. Many SOC reports lead with a Kill Chain summary and then drill into the ATT&CK techniques underneath it - the summary for the reader, the detail for the defenders.

Key points to remember

- Kill Chain = 7 phases, linear, high level. ATT&CK = matrices, granular, behaviour based.
- The Kill Chain tells you where in the attack you are; ATT&CK tells you what the attacker did and how to detect it.
- ATT&CK includes tactics the Kill Chain has no phase for - notably Defense Evasion and Discovery.

- They are complementary, not competing.